

MERIDIAN HEALTH ANALYTICS, INC. — NIST CSF 2.0 GAP ASSESSMENT

Sample GRC portfolio artifact | Fictional company | Assessed against NIST Cybersecurity Framework 2.0 | Assessment date: 2026-02-01

Function	Category ID	Category / Subcategory	Description	Current Maturity (0-4)	Target Maturity (0-4)	Gap	Priority	Evidence / Current State	Remediation Action	Owner
GOVERN	GV.OC	Organizational Context	The organization's mission, stakeholders, and legal/regulatory/contractual requirements are understood and inform cybersecurity risk management	3	4	1	Medium	Add regulatory-driver field to risk register intake so every risk traces to a specific obligation	Compliance Officer	CISO
GOVERN	GV.RM	Risk Management Strategy	Organizational priorities, constraints, and risk tolerance are established and used to support operational risk decisions	2	4	2	High	Draft and board-approve a formal risk appetite statement with quantitative thresholds by risk category	CISO	
GOVERN	GV.RR	Roles, Responsibilities, and Authorities	Cybersecurity roles, responsibilities, and authorities are established, communicated, and enforced					RACI exists for incident response; not yet extended to broader security program governance	Publish enterprise-wide security RACI covering all GRC and engineering functions	
GOVERN	GV.PO	Policy	Organizational cybersecurity policy is established, communicated, and enforced	3	4	1	Medium	Implement policy management tool with automated review reminders and version history	Compliance Officer	
GOVERN	GV.OV	Oversight	Results of organization-wide cybersecurity risk management activities are used to inform, improve, and adjust the strategy	2	3	1	Medium	Institute quarterly board-level cybersecurity risk briefing with standardized reporting template	CISO	
GOVERN	GV.SC	Cybersecurity Supply Chain Risk Management	Cyber supply chain risk management processes are identified, established, managed, monitored, and improved	2	4	2	High	Deploy TPRM platform; require SOC 2/questionnaire before any vendor onboarding	Vendor Risk Manager	CISO
IDENTIFY	ID.AM	Asset Management	Assets (data, hardware, software, systems, facilities) are identified and managed	3	4	1	Medium	Deploy SaaS discovery/CASB tooling to close asset visibility gap	IT Asset Manager	
IDENTIFY	ID.RA	Risk Assessment	The cybersecurity risk to the organization, assets, and individuals is understood	3	4	1	Medium	Extend risk assessment to include threat-intelligence-informed likelihood scoring	GRC Analyst	
IDENTIFY	ID.IM	Improvement	Improvements to organizational cybersecurity risk management processes are identified across all CSF functions	2	3	1	Medium	Stand up CAPA tracker linking incident/audit findings to remediation with due dates and closure verification	CISO	
PROTECT	PR.AA	Identity Management, Authentication, and Access Control	Access to physical and logical assets is limited to authorized users, services, and hardware	2	4	2	High	Roll out PAM with just-in-time access; complete least-privilege access recertification	IAM Manager	CISO
PROTECT	PR.AT	Awareness and Training	Personnel are provided cybersecurity awareness and training	3	4	1	Medium	Move to quarterly training cadence with role-based modules for high-risk groups	Security Awareness Lead	
PROTECT	PR.DS	Data Security	Data is managed consistent with the organization's risk strategy to protect confidentiality, integrity, and availability	2	4	2	High	Complete encryption-at-rest remediation for all PHI-containing systems; enforce via policy and automated scanning	Data Governance Lead	
PROTECT	PR.PS	Platform Security	The hardware, software, and services of physical and virtual platforms are managed consistent with the risk strategy	3	4	1	Medium	Deploy continuous cloud security posture management (CSPM) with automated guardrails	Cloud Security Engineer	
PROTECT	PR.IR	Technology Infrastructure Resilience	Security architectures are managed to protect asset confidentiality, integrity, availability, and resilience	2	3	1	Medium	Stand up tested multi-region failover; conduct semi-annual DR tabletop exercises	Director of Infrastructure	CISO
DETECT	DE.CM	Continuous Monitoring	Assets are monitored to find anomalies, indicators of compromise, and other potentially adverse events	3	4	1	Medium	Onboard colocation facility logs to SIEM; tune detection rules against MITRE ATT&CK healthcare threat profile	Security Operations Lead	
DETECT	DE.AE	Adverse Event Analysis	Anomalies, indicators of compromise, and other potentially adverse events are analyzed to characterize events and detect cybersecurity incidents	3	3	0	Low	Maintain current state; revisit staffing model at next headcount planning cycle	Security Operations Lead	
RESPOND	RS.MA	Incident Management	Responses to detected cybersecurity incidents are managed	3	4	1	Medium	Schedule and conduct IR tabletop exercise; update plan based on findings	Incident Response Lead	
RESPOND	RS.CO	Incident Response Reporting and Communication	Response activities are coordinated with internal and external stakeholders	2	4	2	High	Run breach-notification tabletop scenario involving Legal, Compliance, and Communications	Compliance Officer	CISO
RECOVER	RC.RP	Incident Recovery Plan Execution	Restoration activities are performed to ensure operational availability of systems and services affected by cybersecurity incidents	2	4	2	High	Conduct full-stack recovery exercise measuring actual RTO/RPO against BIA targets	Director of Infrastructure	
RECOVER	RC.CO	Incident Recovery Communication	Restoration activities are coordinated with internal and external parties	3	3	0	Low	Maintain current state	Communications Lead	

MATURITY SUMMARY BY FUNCTION

Function	# Categories Assessed	Avg Current Maturity	Avg Target Maturity	Avg Gap
GOVERN	6	2.4	3.8	1.4
IDENTIFY	3	2.7	3.7	1.0
PROTECT	5	2.4	3.8	1.4
DETECT	2	3.0	3.5	0.5
RESPOND	2	2.5	4.0	1.5
RECOVER	2	2.5	3.5	1.0

GAP ASSESSMENT — METHODOLOGY

Framework	NIST Cybersecurity Framework (CSF) 2.0 — 6 Functions: Govern, Identify, Protect, Detect, Respond, Recover
Maturity Scale	0 = Not Performed, 1 = Ad Hoc, 2 = Repeatable but Informal, 3 = Defined & Managed, 4 = Optimized/Continuously Improved
Gap	Target Maturity minus Current Maturity, calculated automatically
Priority	Gap >= 2 = High Gap = 1 = Medium Gap <= 0 = Low
Scope note	This sample assesses representative Categories, not every CSF Subcategory, to keep the artifact reviewable. A production assessment would score all ~106 CSF 2.0 Subcategories.
Next steps	High-priority gaps feed directly into the Risk Register and inform the annual security roadmap and budget request.